Network & Cyber Security

Interview Questions & Answers Guide

Prepared as an interview-ready reference
Includes: Key Points • Visual Diagrams • Real-World Examples

NETWORK SECURITY INTERVIEW QUESTIONS

Q1. What is a network?

- A network is a group of two or more computers/devices connected together to share data, resources (printers, files) and communication links.
- It uses transmission media like cables, fiber optic, or wireless signals to connect nodes.
- Networks allow resource sharing, centralized data management, and communication (email, file transfer, video calls).

```
  [PC-1]----+
            |
[PC-2]----+---[ SWITCH ]---[ Router ]---( Internet )
            |
[PC-3]----+
```

Diagram: A simple network: end devices connected via a switch, which connects to a router for external access.

Real-World Example: Facebook's 2021 global outage - a faulty BGP (routing) network configuration disconnected Facebook's own network from the internet backbone for ~6 hours, showing how critical correct network config is.

Q2. What is networking?

- Networking is the practice of designing, building, and using networks to connect computers so they can exchange data.
- It involves protocols (rules), hardware (switches, routers) and software (OS network stack) working together.
- Goals of networking include resource sharing, communication, centralized administration, and cost reduction.

```
Design --> Build --> Configure --> Connect --> Communicate
  |          |           |            |            |
Plan IP   Install     Set Protocols  Link Devices  Share Data
```

Diagram: The networking lifecycle from planning to communication.

Real-World Example: Google's global data center interconnect (B4 network) - Google built its own SDN-based backbone network to link data centers worldwide, a landmark real-world networking project.

Q3. Explain the types of networks.

- Networks are classified mainly by geographic scope: PAN, LAN, MAN, and WAN.
- PAN (Personal Area Network) covers a few meters (Bluetooth, USB); LAN covers a building/campus; MAN covers a city; WAN covers countries/continents.
- Other classifications exist too: WLAN (wireless LAN), SAN (storage area network), VPN (virtual private network).

```
PAN (few meters) < LAN (building) < MAN (city) < WAN (country/globe)
  [phone-earbuds]   [office LAN]     [city fiber]   [Internet]
```

Diagram: Network types scale from smallest (PAN) to largest (WAN).

Real-World Example: A hospital chain uses LAN inside each branch, MAN to connect branches within a city, and WAN (via internet/leased lines) to connect branches across the country.

Q4. Explain LAN, MAN, WAN.

- LAN (Local Area Network): connects devices within a small area like an office or home, offering high speed and low cost.
- MAN (Metropolitan Area Network): connects multiple LANs across a city, e.g., cable TV networks or city government networks.
- WAN (Wide Area Network): connects LANs/MANs across countries or continents; the Internet is the largest WAN.

```
[LAN: Office A]---\
                   \
[LAN: Office B]------[ MAN: City Fiber Ring ]-----[ WAN: Internet ]
                   /
[LAN: Office C]---/
```

Diagram: LANs feed into a MAN which connects to the global WAN.

Real-World Example: Reliance Jio built a nationwide WAN fiber backbone (JioFiber) connecting city-level MAN rings to individual home/office LANs across India.

Q5. What is topology and what are the types of topology?

- Network topology is the physical or logical arrangement of nodes and links in a network.
- Physical topology describes actual wiring layout; logical topology describes how data actually flows.
- Common types: Bus, Star, Ring, Mesh, Tree, and Hybrid topology.

```
Bus:   ---o---o---o---o---
Star:      o   o
            \ /
             *  (hub/switch)
            / \
           o   o
Ring:   o---o
        |   |
        o---o
```

Diagram: Basic topology shapes: bus (linear), star (central hub), ring (circular loop).

Real-World Example: Most modern corporate offices use Star topology with a central switch, replacing old Bus/Ethernet coax cable setups from the 1990s.

Q6. Differences between Bus and Star topology.

- Bus topology: all devices share a single central cable (backbone); Star topology: all devices connect individually to a central hub/switch.
- Bus is cheaper to install but a single cable break disrupts the whole network; Star costs more (more cable) but a single node failure doesn't affect others.
- Bus has higher collision/performance issues as more devices join; Star scales and troubleshoots much more easily.

```
BUS:   A---B---C---D---E   (one break = network down)

STAR:      A   B
            \ /
       E----[HUB]----C
            /
           D           (one break = only that node down)
```

Diagram: Bus vs Star: single point of failure comparison.

> **Real-World Example:** Old computer labs used Bus/coax Ethernet (10BASE2); nearly all modern LANs migrated to Star topology using twisted-pair cabling and switches for reliability.

Q7. What is Ring topology?

- In Ring topology, each device connects to exactly two neighboring devices, forming a closed loop.
- Data travels in one direction (or both, in dual-ring) around the ring, passing through each node until it reaches the destination.
- A single cable/node failure can break the whole ring unless a dual-ring or self-healing mechanism is used.

```
       [A]
      /   \
   [D]     [B]
      \   /
       [C]
  Data travels: A -> B -> C -> D -> A
```

Diagram: Devices arranged in a closed circular loop.

> **Real-World Example:** Token Ring networks (IBM, 1980s-90s) and modern SONET/FDDI fiber backbones used in telecom carrier networks still use dual-ring topology for fault tolerance.

Q8. What is Mesh topology?

- In Mesh topology, every device is directly connected to every other device (full mesh) or to several others (partial mesh).
- It provides high redundancy and fault tolerance - if one link fails, data can be rerouted via another path.
- It is expensive and complex to wire/maintain due to the large number of connections (n(n-1)/2 links for full mesh).

```
      [A]-------[B]
      | \       / |
      |  \     /  |
      |   \   /   |
      [D]-------[C]
  Every node connects to every other node
```

Diagram: Full mesh: redundant point-to-point links between all nodes.

Real-World Example: The Internet's backbone routers between ISPs (Tier-1 providers like AT&T, NTT, Lumen) use partial mesh topology to ensure traffic can always find an alternate path if a link fails.

Q9. What is Tree topology?

- Tree topology combines multiple Star networks connected via a central 'root' backbone, forming a hierarchical structure.
- It supports easy expansion - new branches (star networks) can be added without disturbing existing ones.
- A failure in the root/backbone node can bring down large sections of the network below it.

```
              [ROOT Switch]
              /           \
         [Switch-A]     [Switch-B]
         /       \       /      \
      [PC1]    [PC2]   [PC3]   [PC4]
```

Diagram: Hierarchical tree: root switch branching into sub-networks.

Real-World Example: Large university campuses use tree topology - a core backbone switch connects to building-level distribution switches, which connect to access switches in each floor/lab.

Q10. What are network devices? Explain about network devices.

- Network devices are hardware components that enable computers to connect, communicate, and exchange data.
- Common devices: NIC (connects a device to network), Hub/Switch (connects devices in LAN), Router (connects different networks), Repeater (boosts signal), Modem, Firewall, Access Point.
- Each device operates at a specific OSI layer, e.g., Hub/Repeater (Physical), Switch/Bridge (Data Link), Router (Network).

```
[NIC]-[Hub/Switch]-[Router]-[Modem]-[Firewall]-( Internet )
 L1        L1/L2       L3      L1        L3/L4
```

Diagram: Common network devices mapped roughly to OSI layers.

Real-World Example: A typical home setup: laptop NIC -> Wi-Fi router (switch+router+modem combo) -> ISP -> Internet, all working together as different network devices.

Q11. Explain about NIC, HUB, Switch.

- NIC (Network Interface Card): hardware that lets a device physically connect to a network; every device has a unique MAC address burned into its NIC.
- HUB: a basic Layer-1 device that broadcasts incoming data to ALL connected ports, causing collisions and wasted bandwidth.
- Switch: an intelligent Layer-2 device that learns MAC addresses and forwards data only to the intended port, improving speed and security.

```
HUB (broadcasts to all):        SWITCH (sends to correct port):
    A                               A
    |                               |
B--[HUB]--C   (all get the data)  B--[SWITCH]--C  (only C gets it)
    |                               |
    D                               D
```

Diagram: Hub floods data to every port; switch forwards intelligently using MAC table.

Real-World Example: Cisco Catalyst switches replaced hubs in nearly all enterprise networks by the early 2000s because switches reduced collisions and improved security by isolating traffic per port.

Q12. Explain about router and repeater.

- Router: a Layer-3 device that connects different networks and forwards data packets based on IP addresses, choosing the best path (routing).
- Repeater: a Layer-1 device that regenerates and amplifies a weak signal so it can travel farther without degradation.
- Routers make intelligent forwarding decisions using routing tables; repeaters simply boost the signal with no intelligence.

```
[Network A]---[ROUTER]---[Network B]         [Signal]--[REPEATER]-->(boosted signal)
     (chooses best path using IP)             (only amplifies, no decision-making)
```

Diagram: Router connects/routes between networks; repeater only extends signal range.

Real-World Example: Long-distance fiber optic submarine cables (like the 2Africa cable) use optical repeaters every ~100km to amplify light signals across oceans, while ISPs use core routers (Cisco/Juniper) to route traffic between countries.

Q13. Differences between HUB and Switch.

- A Hub operates at the Physical layer (L1) and broadcasts data to all ports; a Switch operates at the Data Link layer (L2) and sends data only to the destination port.
- Hub creates a single collision domain (more collisions, slower); Switch creates a separate collision domain per port (faster, fewer collisions).
- Hub has no MAC address table and no security; Switch maintains a MAC address table and offers better security through traffic isolation.

```
HUB: 1 collision domain for all ports   SWITCH: separate collision domain per port
     [*=====shared=====*]                    [P1]  [P2]  [P3]  [P4]
      P1  P2  P3  P4                          |     |     |     |
                                             [   intelligent switching  ]
```

Diagram: Hub = shared/broadcast; Switch = segmented/intelligent forwarding.

Real-World Example: Enterprise IT teams fully phased out hubs by early 2000s in favor of managed switches (e.g., Cisco, HP Aruba) to support VLANs and reduce network congestion.

Q14. What is Internet, Intranet and Extranet?

- Internet: a global, public network of interconnected networks accessible to anyone, using TCP/IP.
- Intranet: a private network restricted to an organization's employees, used for internal communication, portals, and resources.
- Extranet: an extension of an intranet that allows limited, controlled access to external parties like vendors, partners, or clients.

```
          ( INTERNET - Public, Global )
                       |
    ------------------------------------
    |                                  |
[INTRANET - internal employees]   [EXTRANET - partners/vendors,
                                    controlled external access]
```

Diagram: Internet is public and global; Intranet is private/internal; Extranet allows selective external access.

Real-World Example: Infosys uses an internal Intranet portal (Infosys Sparsh) for employees, and an Extranet portal for client project collaboration with controlled logins.

Q15. What is IP Address and types/versions of IP address?

- An IP Address is a unique numerical label assigned to each device on a network, used to identify and locate it for communication.
- There are two main versions: IPv4 (32-bit, e.g., 192.168.1.1) and IPv6 (128-bit, e.g., 2001:db8::1).
- IP addresses are also classified as Public (internet-routable) or Private (used within local networks) and Static or Dynamic (assigned via DHCP).

```
IP Address
  |
  +-- IPv4 (32-bit)  e.g. 192.168.1.1
  +-- IPv6 (128-bit) e.g. 2001:0db8::1
       |
       +-- Public IP  (internet-facing)
       +-- Private IP (LAN-only)
```

Diagram: IP address classification tree: version, and public vs private.

Real-World Example: IPv4 address exhaustion led ICANN/RIRs to run out of new IPv4 blocks around 2011-2019 globally, accelerating the industry-wide push to adopt IPv6.

Q16. What is IPv4?

- IPv4 is a 32-bit addressing scheme, written as four decimal octets separated by dots (e.g., 192.168.0.1), giving about 4.3 billion unique addresses.
- It uses classes (A, B, C, D, E) and supports subnetting via subnet masks to divide networks logically.
- Due to explosive internet growth, IPv4 addresses have been exhausted, driving adoption of NAT and IPv6.

```
 192  .  168  .  0  .  1
[8bit][8bit][8bit][8bit]  = 32 bits total
```

Diagram: IPv4 address structure: four 8-bit octets.

Real-World Example: Most home Wi-Fi routers still assign private IPv4 addresses like 192.168.1.x to connected devices, even though public IPv4 addresses ran out years ago.

Q17. What is IPv6?

- IPv6 is a 128-bit addressing scheme written in 8 groups of hexadecimal numbers (e.g., 2001:0db8:85a3::8a2e:0370:7334), designed to replace IPv4.
- It provides an enormously larger address space (~340 undecillion addresses), solving IPv4 exhaustion.
- IPv6 offers built-in security (IPSec support), simplified header format, and no need for NAT.

```
2001:0db8:85a3:0000:0000:8a2e:0370:7334
[16][ 16][ 16][ 16][ 16][ 16][ 16][ 16] bits = 128 bits total
```

Diagram: IPv6 address structure: eight 16-bit hextets.

Real-World Example: Reliance Jio in India runs a majority IPv6-only mobile network (one of the largest IPv6 deployments globally) to handle hundreds of millions of subscriber devices.

Q18. Differences between IPv4 and IPv6.

- IPv4 uses 32-bit addresses (~4.3 billion); IPv6 uses 128-bit addresses (virtually unlimited).
- IPv4 addresses are written in decimal (dotted notation); IPv6 addresses are written in hexadecimal (colon notation).
- IPv4 requires NAT to conserve addresses and lacks built-in security; IPv6 supports auto-configuration and has native IPSec support.

```
IPv4: 192.168.1.1             (32-bit, decimal, NAT often needed)
IPv6: 2001:db8::1             (128-bit, hex, no NAT needed, built-in IPSec)
```

Diagram: Side-by-side format comparison of IPv4 vs IPv6.

Real-World Example: Google reports (via its IPv6 statistics page) that global IPv6 adoption crossed 40-45% of users by the mid-2020s, showing gradual worldwide migration from IPv4.

Q19. Explain about Public IP and Private IP.

- Public IP: a globally unique address assigned by an ISP, routable directly over the internet.
- Private IP: an address used within a local network (ranges like 10.x.x.x, 172.16-31.x.x, 192.168.x.x) that is NOT routable on the public internet.
- Devices with private IPs access the internet via NAT (Network Address Translation) on the router, which maps them to a single public IP.

```
[PC:192.168.1.5]--\
[PC:192.168.1.6]---[Router w/ NAT]---(Public IP: 103.25.10.4)---Internet
[PC:192.168.1.7]--/
```

Diagram: Multiple private IPs share one public IP via NAT.

Real-World Example: All devices on a home Wi-Fi (phones, laptops, smart TV) get private IPs from the router, but they all appear as one public IP to external websites - this is how ISPs conserve limited IPv4 addresses.

Q20. What is WWW?

- WWW (World Wide Web) is a system of interlinked hypertext documents/resources accessed via the Internet using web browsers.
- It works using HTTP/HTTPS protocol, URLs (addresses), and HTML (content structure), invented by Tim Berners-Lee in 1989.
- WWW is a service that runs ON the Internet - the Internet is the underlying network infrastructure, while WWW is one application/service using it.

```
Browser --(HTTP/HTTPS request)--> Web Server --(HTML/CSS/JS response)--> Browser renders page
                    via URL: https://www.example.com
```

Diagram: Basic request-response flow of the World Wide Web.

Real-World Example: Tim Berners-Lee created the WWW at CERN in 1989-1991, and the first website (info.cern.ch) is still preserved online today as a historical reference.

Q21. What is protocol? Types of protocols.

- A protocol is a set of rules that governs how data is formatted, transmitted, and received between devices on a network.
- Protocols ensure devices from different vendors/systems can communicate using a common language.
- Common types: HTTP/HTTPS (web), FTP (file transfer), SMTP (email), TCP/UDP (transport), IP (addressing), DNS (name resolution).

```
Protocols by function:
 Web: HTTP, HTTPS      Mail: SMTP, IMAP, POP3
 File Transfer: FTP     Naming: DNS
 Transport: TCP, UDP    Network: IP, ICMP
```

Diagram: Protocols grouped by the function they serve.

Real-World Example: When the DNS protocol failed at a Facebook data center in 2021, it made Facebook, Instagram and WhatsApp completely unreachable worldwide for hours despite servers being up.

Q22. What is HTTP?

- HTTP (HyperText Transfer Protocol) is an application-layer protocol used to transfer web pages/resources between a client (browser) and a server.
- It is stateless (each request is independent) and works on a request-response model over TCP, typically port 80.
- Data sent via HTTP is NOT encrypted, making it vulnerable to eavesdropping and man-in-the-middle attacks.

```
Browser --GET /page.html-->  [Web Server]
Browser <--200 OK + HTML----  (Port 80, unencrypted)
```

Diagram: Basic unencrypted HTTP request-response cycle.

Real-World Example: Older websites using plain HTTP were flagged as 'Not Secure' by Chrome starting 2018, pushing the entire web industry to migrate to HTTPS.

Q23. What is HTTPS?

- HTTPS (HTTP Secure) is HTTP combined with SSL/TLS encryption, securing data exchanged between browser and server.
- It uses port 443 and provides confidentiality (encryption), integrity (data not tampered), and authentication (via SSL certificates).
- HTTPS protects against eavesdropping, man-in-the-middle attacks, and data tampering during transmission.

```
Browser <==TLS/SSL Encrypted Tunnel==> [Web Server]
       (Port 443, certificate verified)
```

Diagram: HTTPS wraps HTTP traffic in an encrypted TLS tunnel.

Real-World Example: Let's Encrypt (launched 2015) provided free SSL certificates, driving HTTPS adoption on the web from ~40% to over 90% of page loads within a decade.

Q24. Differences between HTTP and HTTPS.

- HTTP transmits data in plain text; HTTPS encrypts data using SSL/TLS.
- HTTP uses port 80; HTTPS uses port 443.
- HTTP does not verify server identity; HTTPS uses digital certificates to authenticate the server, and shows a padlock icon in browsers.

```
HTTP  : Browser <--plain text--> Server   (Port 80)  [no lock icon]
HTTPS : Browser <--encrypted---> Server   (Port 443) [padlock icon]
```

Diagram: Encryption and port comparison between HTTP and HTTPS.

Real-World Example: Google Chrome and other browsers began actively warning users with a 'Not Secure' label on any HTTP site collecting form data, forcing e-commerce sites worldwide to switch to HTTPS.

Q25. What is TCP?

- TCP (Transmission Control Protocol) is a connection-oriented transport layer protocol that guarantees reliable, ordered, and error-checked delivery of data.
- It establishes a connection using a 3-way handshake (SYN, SYN-ACK, ACK) before data transfer, and retransmits lost packets.
- TCP is used where reliability matters more than speed, e.g., web browsing, email, file transfer.

```
Client            Server
  |---SYN-------->|
  |<--SYN-ACK-----|
  |---ACK-------->|
  |===data flow===|   (3-way handshake before data transfer)
```

Diagram: TCP's 3-way handshake establishes a reliable connection.

Real-World Example: Every time you load a website or send an email, TCP ensures no data packet is lost or arrives out of order - critical for banking transactions and file downloads.

Q26. What is UDP?

- UDP (User Datagram Protocol) is a connectionless transport layer protocol that sends data without establishing a prior connection or guaranteeing delivery.
- It has lower overhead and latency than TCP since there's no handshake, acknowledgment, or retransmission.
- UDP is used where speed matters more than reliability, e.g., video streaming, online gaming, VoIP, DNS queries.

```
Client               Server
  |---data packet 1-------->|  (no handshake, no guarantee of delivery)
  |---data packet 2----X    |  (lost packet not resent)
```

Diagram: UDP sends data directly without connection setup or delivery guarantees.

Real-World Example: Zoom and Google Meet use UDP for real-time audio/video because a few dropped packets (minor glitches) are preferable to the delay TCP retransmission would cause in a live call.

Q27. Differences between TCP and UDP.

- TCP is connection-oriented (handshake required); UDP is connectionless (no handshake).
- TCP guarantees reliable, ordered delivery with error-checking and retransmission; UDP offers no such guarantee, making it faster but less reliable.
- TCP is used for web, email, file transfer; UDP is used for streaming, gaming, VoIP, DNS.

```
TCP: Reliable, Ordered, Slower   -> Web, Email, File Transfer
UDP: Fast, Unordered, No Guarantee -> Video calls, Gaming, DNS, Streaming
```

Diagram: Trade-off comparison: TCP prioritizes reliability, UDP prioritizes speed.

Real-World Example: Online multiplayer games like PUBG/Call of Duty use UDP to minimize lag, while banking apps use TCP to make sure every transaction packet arrives correctly and in order.

Q28. Explain about remote login in extranet.

- Remote login in an extranet allows authorized external users (partners, vendors, remote employees) to securely access specific internal resources over the internet.
- It's typically implemented using VPN, SSH, or RDP combined with strong authentication (MFA) and strict access control policies.
- Security measures like encryption, firewalls, and role-based access are essential to prevent unauthorized access through this remote entry point.

```
[Remote Vendor] --VPN Tunnel (encrypted)--> [Extranet Gateway/Firewall] --> [Internal Resource]
                  (authenticated login required)
```

Diagram: Secure remote login into an extranet via an encrypted VPN tunnel.

Real-World Example: The 2013 Target Corporation breach began when attackers stole credentials from an HVAC vendor who had remote extranet access to Target's network, exposing 40 million credit cards.

Q29. What is OSI reference model? Types of layers in OSI model.

- The OSI (Open Systems Interconnection) model is a 7-layer conceptual framework that standardizes how different systems communicate over a network.
- The 7 layers (top to bottom): Application, Presentation, Session, Transport, Network, Data Link, Physical - remembered as 'All People Seem To Need Data Processing'.
- Each layer has a specific function and communicates only with the layer directly above/below it, making troubleshooting and standardization easier.

```
7. Application   (HTTP, FTP, SMTP)
6. Presentation   (Encryption, Compression)
5. Session        (Session Management)
4. Transport      (TCP, UDP)
3. Network        (IP, Routing)
2. Data Link      (MAC, Switches)
1. Physical       (Cables, Signals)
```

Diagram: The 7 layers of the OSI model, top (application) to bottom (physical).

Real-World Example: Network engineers use the OSI model daily to troubleshoot issues - e.g., 'is this a Layer 1 cable problem or a Layer 3 routing problem?' is a standard diagnostic approach at companies like Cisco and AWS.

Q30. What is Application layer? Explain about services of application layer.

- The Application layer (Layer 7) is the topmost OSI layer that directly interacts with end-user applications and provides network services to them.
- Key services include: email (SMTP), file transfer (FTP), web browsing (HTTP), remote login (Telnet/SSH), and name resolution (DNS).
- It does not include the actual applications themselves, but provides the interface/protocols that applications use to communicate over the network.

```
      [User Application - e.g. Browser, Email Client]
                        |
              APPLICATION LAYER
     (HTTP, FTP, SMTP, DNS, Telnet services)
                        |
                [Lower OSI Layers]
```

Diagram: Application layer sits between user apps and the rest of the network stack.

Real-World Example: When you send a Gmail email, the Application layer's SMTP protocol handles composing/sending it, while DNS resolves gmail.com's server address - both application-layer services working together.

Q31. Explain about protocols in application layer.

- HTTP/HTTPS: used for web browsing and transferring web page data.
- FTP: used for transferring files between client and server; SMTP/IMAP/POP3: used for sending and receiving emails.
- DNS: resolves domain names to IP addresses; Telnet/SSH: used for remote login/administration of devices.

```
Application Layer Protocols:
 Web: HTTP, HTTPS       Email: SMTP, IMAP, POP3
 File: FTP, SFTP        Naming: DNS
 Remote Access: Telnet, SSH
```

Diagram: Grouping of the key application-layer protocols by use case.

Real-World Example: The 2020 SolarWinds attack abused legitimate application-layer protocols (HTTP/DNS) to quietly exfiltrate data, disguising malicious traffic as normal application-layer communication.

Q32. What is Presentation layer? Explain about functionality of presentation layer.

- The Presentation layer (Layer 6) formats/translates data between the application layer and the network, ensuring data is readable across different systems.
- Its key functions are: data translation (character encoding), data compression (reduce size for efficient transfer), and data encryption (secure data).
- It acts as a 'translator' - converting data into a common format both sender and receiver can understand (e.g., ASCII, JPEG, MP3).

```
[Application Data] --> PRESENTATION LAYER --> [Session Layer]
       Functions: Translate | Compress | Encrypt
```

Diagram: Presentation layer transforms data via translation, compression, encryption.

Real-World Example: When you watch a Netflix video, the presentation layer's encoding/compression (H.264/H.265 codecs) shrinks video size for streaming, while TLS encryption (also handled here conceptually) secures it.

Q33. Explain about data translation in presentation layer.

- Data translation converts data from the sending system's format into a common format that the receiving system can understand.
- It handles differences in character encoding (e.g., ASCII vs EBCDIC) and data representation between different operating systems/architectures.
- This ensures interoperability - a file created on a Windows PC can be correctly read on a Mac or Linux system.

```
[Sender - EBCDIC format] --> [Translation: Common Format] --> [Receiver - ASCII format]
```

Diagram: Translation converts between different data encoding formats for compatibility.

Real-World Example: Unicode/UTF-8 standardization allows a message typed in Hindi or Arabic script on one device to display correctly on any other device worldwide, solving old character-encoding mismatch problems.

Q34. Explain about data compression in presentation layer.

- Data compression reduces the size of data before transmission, saving bandwidth and speeding up transfer.
- It can be lossless (no data lost, e.g., ZIP, PNG) or lossy (some quality lost for smaller size, e.g., JPEG, MP3).
- Compression is especially important for multimedia (audio/video streaming) where large files must be transmitted efficiently over limited bandwidth.

```
[Original File: 100MB] --Compression--> [Compressed File: 20MB] --> Network Transfer (faster)
```

Diagram: Compression shrinks data size before sending it over the network.

Real-World Example: Streaming platforms like YouTube use video compression (VP9/AV1 codecs) to deliver HD video using a fraction of the raw bandwidth, enabling smooth streaming even on moderate internet speeds.

Q35. Explain about data encryption in presentation layer.

- Data encryption converts readable data (plaintext) into an unreadable format (ciphertext) to protect it from unauthorized access during transmission.
- The presentation layer applies encryption/decryption logic conceptually before data is sent to the session/transport layers.
- Common encryption methods include SSL/TLS for web traffic and various symmetric/asymmetric algorithms (AES, RSA).

```
[Plaintext: "Hello"] --Encrypt (Key)--> [Ciphertext: "X$7!q@"] --Network--> --Decrypt--> [Plaintext: "Hello"]
```

Diagram: Encryption transforms readable data into unreadable ciphertext for safe transit.

Real-World Example: WhatsApp's end-to-end encryption (based on the Signal Protocol) ensures messages are encrypted on the sender's device and only decrypted on the receiver's device, protecting billions of daily chats.

Q36. Explain about protocols in presentation layer.

- SSL/TLS: provides encryption and secure communication for protocols like HTTPS.
- JPEG, GIF, PNG, MPEG: standard formats for image/video representation and compression, conceptually tied to presentation-layer functions.
- ASCII, EBCDIC, Unicode: character encoding standards for data translation between systems.

```
Presentation-related standards:
 Security: SSL/TLS
 Media Formats: JPEG, PNG, MPEG
 Encoding: ASCII, Unicode, EBCDIC
```

Diagram: Key standards/protocols associated with presentation-layer functions.

Real-World Example: Every HTTPS website relies on TLS (a presentation/session-layer concept) to encrypt data - the padlock icon in your browser confirms this protocol is active.

Q37. What is Session layer? Explain about functionality of session layer.

- The Session layer (Layer 5) establishes, manages, and terminates communication sessions between two devices/applications.
- It handles session synchronization (checkpoints for resuming interrupted transfers) and dialog control (deciding who transmits, when, in full-duplex or half-duplex mode).
- It ensures that data from different sessions/applications doesn't get mixed up, keeping each conversation isolated and organized.

```
[Device A] --Establish Session--> [Device B]
            --Maintain / Sync-->
            --Terminate Session-->
```

Diagram: Session layer manages the full lifecycle of a communication session: open, maintain, close.

Real-World Example: When a large file transfer or video call drops mid-way and resumes from the same checkpoint instead of restarting, that's the session layer's synchronization functionality at work (e.g., resumable downloads).

Q38. Differences between authentication and authorization.

- Authentication verifies WHO a user is (identity check) - e.g., entering a username/password or using biometrics.
- Authorization determines WHAT an authenticated user is allowed to do/access (permission check).
- Authentication always happens first; authorization happens after, based on the authenticated identity's assigned privileges/roles.

```
User --> [AUTHENTICATION: Who are you? Login/Password/OTP] --> Identity Verified
      --> [AUTHORIZATION: What can you access? Role/Permissions] --> Access Granted/Denied
```

Diagram: Authentication (identity) happens before authorization (permissions).

Real-World Example: Logging into your company email (authentication) doesn't mean you can access the finance department's shared drive - that additional access requires separate authorization/role assignment.

Q39. What is API? Explain about NetBIOS API.

- API (Application Programming Interface) is a set of rules/protocols that allows different software applications to communicate and exchange data with each other.
- NetBIOS (Network Basic Input/Output System) is a session-layer API that allows applications on different computers to communicate over a LAN, providing name resolution, session management, and datagram services.
- NetBIOS is largely legacy technology today, mostly superseded by TCP/IP-based naming (DNS) but still exists in some Windows file-sharing environments (NetBIOS over TCP/IP).

```
[App on PC-A] <--NetBIOS API (name resolution, sessions)--> [App on PC-B]
                    (Legacy Windows LAN communication)
```

Diagram: NetBIOS API enabling name-based communication between apps on a LAN.

Real-World Example: The infamous WannaCry ransomware (2017) exploited the SMB/NetBIOS-related protocol (EternalBlue vulnerability) to self-propagate across networks, infecting 200,000+ computers in 150 countries.

Q40. What is Transport layer? Explain about functionality of transport layer.

- The Transport layer (Layer 4) is responsible for end-to-end delivery of data between source and destination applications, using ports to identify specific processes.
- Its key functions: segmentation (breaking data into segments), flow control (matching sender/receiver speed), error control (detecting/correcting errors), and connection control (TCP) or connectionless delivery (UDP).
- It ensures complete, reliable (if TCP) data transfer, and multiplexes multiple application streams over a single network connection using port numbers.

```
[App Data] --> Segmentation --> [Seg1][Seg2][Seg3] --> Transport (TCP/UDP, Port#) --> Destination App
```

Diagram: Transport layer breaks data into segments and delivers them to the right application via ports.

Real-World Example: When you have Zoom, Chrome, and Spotify open simultaneously, the transport layer's port numbers (e.g., 443, 8801) ensure each application's data goes to the right place without mixing up.

Q41. What is a Segment?

- A segment is a unit of data at the Transport layer, created when the transport layer breaks down data from upper layers into smaller, manageable pieces.
- Each segment includes a header containing source/destination port numbers, sequence numbers, and error-checking information (in TCP).
- Segments are reassembled in the correct order at the receiving end to reconstruct the original data.

```
[Large Data] --> [Header|Seg1] [Header|Seg2] [Header|Seg3] --> sent over network --> reassembled at destination
```

Diagram: Data broken into headers + segments at the transport layer.

Real-World Example: When downloading a large software update, TCP breaks the file into thousands of segments, each tracked and reassembled in order - if one segment is lost, only that piece is retransmitted.

Q42. Explain protocols in transport layer.

- TCP (Transmission Control Protocol): connection-oriented, reliable, ordered delivery - used for web, email, file transfer.
- UDP (User Datagram Protocol): connectionless, fast, no delivery guarantee - used for streaming, gaming, VoIP, DNS.
- Both operate using port numbers to identify specific applications/services (e.g., port 80 for HTTP, port 53 for DNS).

```
Transport Layer Protocols:
  TCP -> Reliable  -> Web, Email, File Transfer
  UDP -> Fast      -> Streaming, Gaming, DNS
```

Diagram: The two core transport-layer protocols and their typical use cases.

Real-World Example: Netflix uses TCP to load its website/menu (reliability matters) but may use UDP-based protocols for actual video streaming segments to prioritize smooth playback over occasional glitches.

Q43. What is Network layer? Explain about functionality of network layer.

- The Network layer (Layer 3) is responsible for logical addressing (IP addresses) and routing data packets between different networks to reach the correct destination.
- Its key functions: logical addressing, routing/path determination, and packet forwarding across multiple interconnected networks.
- Routers operate at this layer, using routing tables and protocols (like OSPF, BGP) to determine the best path for data.

```
[Packet: Src IP, Dst IP] --> [Router 1] --> [Router 2] --> [Router 3] --> Destination Network
            (Best path chosen via routing table)
```

Diagram: Network layer routes packets across multiple networks using IP addressing.

Real-World Example: When you access a website hosted in the USA from India, network-layer routers (using BGP) determine the best path across dozens of intermediate networks in milliseconds.

Q44. Explain about routing and path determination.

- Routing is the process of selecting the best path for data packets to travel from source to destination across interconnected networks.
- Path determination uses routing algorithms/protocols (e.g., OSPF, RIP, BGP) that consider factors like hop count, bandwidth, delay, and cost to choose the optimal route.
- Routers maintain routing tables that are updated dynamically (dynamic routing) or manually configured (static routing) to reflect the best available paths.

```
Source --> [Router A] --3 hops, low bandwidth--> Destination
       --> [Router B] --2 hops, high bandwidth--> Destination  <-- CHOSEN (better path)
```

Diagram: Routers compare multiple paths and select the optimal one to a destination.

Real-World Example: BGP (Border Gateway Protocol) route leaks/hijacks - like the 2008 Pakistan Telecom incident that accidentally rerouted global YouTube traffic through Pakistan - show how critical correct path determination is.

Q45. Explain about logical addressing.

- Logical addressing refers to IP addresses assigned to devices at the Network layer, which can change based on the network the device connects to.
- It allows devices to be identified and located across different networks, enabling routing between them.
- Unlike physical (MAC) addresses, logical addresses are hierarchical (network + host portion), which makes routing scalable across large networks like the Internet.

```
IP Address: 192.168.1.10
           [Network Part][Host Part]
           (identifies which network, then which device on it)
```

Diagram: IP addresses split into network and host portions for scalable routing.

Real-World Example: When you travel and connect your laptop to a different Wi-Fi network, it gets a new logical (IP) address each time, while its physical (MAC) address never changes.

Q46. Explain about physical addressing.

- Physical addressing refers to the MAC (Media Access Control) address, a unique 48-bit identifier burned into a device's NIC by the manufacturer.
- It operates at the Data Link layer and is used for communication within the same local network segment.
- Unlike IP addresses, MAC addresses are fixed/permanent (though they can be spoofed) and do not change when a device moves to a different network.

```
MAC Address Example: 00:1A:2B:3C:4D:5E
  (Fixed, assigned by manufacturer, used for local delivery)
```

Diagram: MAC address: a fixed hardware identifier used for local network delivery.

Real-World Example: MAC address filtering is used in corporate/home Wi-Fi security to allow only specific known devices to connect, though attackers can 'spoof' a MAC address to bypass this.

Q47. Differences between logical addressing and physical addressing.

- Logical addressing (IP address) operates at the Network layer; physical addressing (MAC address) operates at the Data Link layer.
- IP addresses can change depending on the network a device joins; MAC addresses are fixed/permanent (assigned by hardware manufacturer).
- IP addresses are used for routing data across different networks; MAC addresses are used for delivering data within the same local network segment.

```
LOGICAL (IP): 192.168.1.10   -- changes per network, used for routing (Layer 3)
PHYSICAL (MAC): 00:1A:2B:3C  -- fixed, used for local delivery (Layer 2)
```

Diagram: Key contrasts between IP (logical) and MAC (physical) addressing.

Real-World Example: ARP (Address Resolution Protocol) bridges these two - it maps a known IP address to the corresponding MAC address on a LAN; ARP spoofing attacks exploit this mapping to intercept traffic.

Q48. What is MAC address?

- A MAC (Media Access Control) address is a unique 48-bit (6-byte) hardware identifier assigned to a device's network interface card by its manufacturer.
- It is written in hexadecimal format, e.g., 00:1A:2B:3C:4D:5E, with the first half identifying the manufacturer (OUI) and the second half the specific device.
- MAC addresses operate at the Data Link layer (Layer 2) and are used to identify devices for communication within the same local network.

```
00:1A:2B : 3C:4D:5E
[Manufacturer ID] [Device Serial]
```

Diagram: MAC address structure: manufacturer prefix + unique device identifier.

Real-World Example: Retail stores and airports use MAC address tracking of visitors' phone Wi-Fi signals for anonymous footfall analytics - a real privacy/security consideration tied to MAC addresses.

Q49. What is Physical layer?

- The Physical layer (Layer 1) is the lowest OSI layer, responsible for the actual transmission of raw bits (0s and 1s) over a physical medium.
- It deals with hardware elements: cables (copper, fiber), connectors, voltage levels, radio frequencies, and data rates.
- Devices like hubs, repeaters, and network cables operate purely at this layer, with no awareness of data meaning - only raw signal transmission.

```
[Bits: 1 0 1 1 0] --> Electrical/Optical/Radio Signal --> Transmitted over Cable/Fiber/Air
```

Diagram: Physical layer converts data bits into transmittable signals over a medium.

Real-World Example: Fiber optic cable cuts (accidental, like construction digging, or deliberate, like suspected sabotage of undersea cables in the Baltic Sea in 2023-24) are physical-layer failures that can disrupt entire countries' internet.

Q50. What is encryption algorithm? Types of encryption algorithm.

- An encryption algorithm is a mathematical procedure used to convert readable data (plaintext) into unreadable ciphertext to protect confidentiality.
- There are two main types: Symmetric algorithms (same key for encryption/decryption, e.g., AES, DES) and Asymmetric algorithms (different keys - public/private, e.g., RSA, ECC).
- Hashing algorithms (like SHA-256) are related but different - they are one-way functions used for integrity verification, not reversible encryption.

```
Encryption Algorithms
  |
  +-- Symmetric (same key)      e.g., AES, DES
  +-- Asymmetric (public/private key) e.g., RSA, ECC
```

Diagram: Two main categories of encryption algorithms.

Real-World Example: AES-256 (symmetric) is used by governments and banks worldwide (including the US government for classified data) as the current gold-standard encryption algorithm.

Q51. What is symmetric algorithm?

- A symmetric algorithm uses the SAME key for both encryption and decryption of data.
- It is fast and efficient for encrypting large amounts of data, making it ideal for bulk data encryption.
- The main challenge is securely sharing/distributing the single key between sender and receiver without it being intercepted.

```
[Plaintext] --Encrypt (Key K)--> [Ciphertext] --Decrypt (same Key K)--> [Plaintext]
```

Diagram: Symmetric encryption: one shared key for both encrypting and decrypting.

Real-World Example: AES (Advanced Encryption Standard) is the symmetric algorithm used to encrypt Wi-Fi traffic (WPA2/WPA3) and disk encryption (BitLocker) worldwide.

Q52. What is Asymmetric algorithm?

- An asymmetric algorithm uses a pair of mathematically related keys: a public key (shared openly) for encryption, and a private key (kept secret) for decryption.
- It solves the key-distribution problem of symmetric encryption since the public key can be shared freely without compromising security.
- It is slower than symmetric encryption, so it's typically used for secure key exchange and digital signatures rather than bulk data encryption.

```
[Plaintext] --Encrypt (Public Key)--> [Ciphertext] --Decrypt (Private Key)--> [Plaintext]
     (Public key shared openly; Private key kept secret by receiver)
```

Diagram: Asymmetric encryption: public key encrypts, only the matching private key decrypts.

Real-World Example: RSA asymmetric encryption underlies HTTPS/TLS certificate exchange for nearly every secure website on the internet, including banking and e-commerce sites.

Q53. Differences between symmetric and asymmetric algorithm.

- Symmetric algorithm uses one shared key; asymmetric algorithm uses a public-private key pair.
- Symmetric is faster and suited for large data volumes; asymmetric is slower but solves secure key distribution.
- Symmetric examples: AES, DES; Asymmetric examples: RSA, ECC, Diffie-Hellman.

```
SYMMETRIC:  [Key] used for both Encrypt & Decrypt  -> Fast   -> AES, DES
ASYMMETRIC: [Public Key] Encrypt, [Private Key] Decrypt -> Slower -> RSA, ECC
```

Diagram: Speed vs key-management trade-off between symmetric and asymmetric encryption.

Real-World Example: HTTPS/TLS uses BOTH: asymmetric encryption (RSA) to securely exchange a session key during handshake, then symmetric encryption (AES) for the fast bulk encryption of actual browsing data.

Q54. Explain about public key and private key.

- A public key is a cryptographic key that can be shared openly with anyone and is used to encrypt data or verify a digital signature.
- A private key is kept strictly secret by its owner and is used to decrypt data encrypted with the corresponding public key, or to create a digital signature.
- Together they form an asymmetric key pair - mathematically linked such that data encrypted with one can only be decrypted with the other.

```
     Public Key (shared)          Private Key (secret)
           |                              |
  Anyone can encrypt data  --->  Only owner can decrypt data
           |                              |
  Used to verify signature <--- Used to create signature
```

Diagram: Public-private key pair: opposite roles in encryption and signing.

Real-World Example: When you install an app, your device verifies its digital signature using the developer's public key (e.g., Apple/Google's code-signing system) to confirm the app hasn't been tampered with.

Q55. What is digital signature?

- A digital signature is a cryptographic mechanism that verifies the authenticity and integrity of a digital message or document, and confirms the sender's identity.
- It works by hashing the message and encrypting that hash with the sender's PRIVATE key; the receiver decrypts it with the sender's PUBLIC key and compares hashes.
- It provides non-repudiation - the sender cannot later deny having sent the signed message, since only their private key could have created that signature.

```
Sender: [Message] --Hash--> [Hash] --Encrypt w/ Private Key--> [Digital Signature]
Receiver: Decrypt Signature w/ Public Key --> Compare with re-computed Hash --> Match = Valid
```

Diagram: Digital signature creation and verification using hashing + private/public keys.

Real-World Example: Software vendors like Microsoft digitally sign Windows updates so your PC can verify the update genuinely came from Microsoft and wasn't tampered with by malware before installation.

Q56. Explain about firewall in network security.

- A firewall is a network security device/software that monitors and controls incoming/outgoing traffic based on predefined security rules.
- It acts as a barrier between a trusted internal network and untrusted external networks (like the Internet), blocking unauthorized access.
- Types include packet-filtering firewalls, stateful inspection firewalls, proxy firewalls, and next-generation firewalls (NGFW) with deep packet inspection.

```
(Internet - Untrusted) ---> [ FIREWALL: allow/deny rules ] ---> (Internal Network - Trusted)
               Blocked traffic  X
               Allowed traffic  ->
```

Diagram: Firewall filtering traffic between untrusted internet and trusted internal network.

Real-World Example: The 2017 Equifax breach occurred partly because a known vulnerability (Apache Struts) wasn't patched and firewall/WAF rules failed to block the exploit, exposing 147 million people's data.

CYBER SECURITY INTERVIEW QUESTIONS

Q1. What is cyber security? Explain advantages of cyber security.

- Cyber security is the practice of protecting systems, networks, applications, and data from digital attacks, unauthorized access, and damage.
- It covers domains like network security, application security, cloud security, and endpoint security, often using the CIA triad (Confidentiality, Integrity, Availability) as its core goal.
- Advantages: protects sensitive data/privacy, prevents financial loss, maintains business reputation, ensures regulatory compliance, and enables safe digital operations.

```
       CIA TRIAD (Goal of Cyber Security)
             Confidentiality
            /              \
    Integrity ------------ Availability
```

Diagram: The CIA Triad: the three core goals cyber security aims to protect.

Real-World Example: After the 2017 WannaCry ransomware attack crippled the UK's NHS hospitals, healthcare systems worldwide massively increased cyber security investment to prevent similar disruptions.

Q2. Who is a Hacker? Explain different types of hackers.

- A hacker is a person skilled in computer systems/networks who finds and exploits vulnerabilities - the intent behind their actions defines whether they are helpful or harmful.
- Main types: White Hat (ethical, authorized), Black Hat (malicious, unauthorized), Grey Hat (in-between, unauthorized but not malicious intent).
- Other types include: Script Kiddies (use existing tools without deep knowledge), Hacktivists (politically/socially motivated), and State-sponsored hackers (work for governments).

```
Hacker
  |
  +-- White Hat  (Ethical, Authorized)
  +-- Grey Hat   (Unauthorized, not malicious)
  +-- Black Hat  (Malicious, Illegal)
  +-- Hacktivist / Script Kiddie / State-sponsored
```

Diagram: Classification of hackers by intent and authorization.

Real-World Example: Kevin Mitnick, once a notorious black-hat hacker in the 1990s, later became a respected white-hat security consultant - illustrating the intent-based classification of hackers.

Q3. Explain about Black hat hacker, gray hat hacker and white hat hacker.

- Black Hat Hacker: breaks into systems illegally with malicious intent - to steal data, cause damage, or for financial gain.
- White Hat Hacker: an ethical hacker authorized by the organization to find and fix vulnerabilities (penetration testers, security researchers).
- Grey Hat Hacker: hacks without authorization (technically illegal) but usually without malicious intent, often reporting the vulnerability afterward.

```
  BLACK HAT          GREY HAT             WHITE HAT
(Illegal+Malicious) (Illegal, no harm)  (Legal+Authorized)
     X  X               ?  ?                OK OK
```

Diagram: Spectrum of hacker types by legality and intent.

Real-World Example: HackerOne and Bugcrowd run bug bounty platforms where white-hat hackers legally find vulnerabilities for companies like Google and Apple in exchange for financial rewards.

Q4. Differences between black hat and gray hat hackers.

- Black hat hackers act with clear malicious intent (theft, damage, extortion); grey hat hackers usually don't intend harm, often hacking out of curiosity or to expose flaws.
- Black hat activities are always illegal and unauthorized; grey hat activities are technically unauthorized/illegal too, but often disclosed responsibly afterward.
- Black hats seek personal/financial gain from victims; grey hats sometimes seek recognition or may request a reward after voluntarily reporting the flaw.

```
BLACK HAT: Find flaw -> Exploit for gain -> Cause harm
GREY HAT:  Find flaw -> Test without permission -> Report to owner (no harm intended)
```

Diagram: Behavioral flow comparing black hat vs grey hat hacker actions.

Real-World Example: In 2013, a grey-hat hacker exploited a Facebook bug to post on Mark Zuckerberg's own wall (after Facebook ignored his responsible disclosure) to prove the vulnerability was real - illegal, but not malicious.

Q5. Explain about offensive and defensive security.

- Offensive security involves proactively simulating attacks (penetration testing, red teaming) to find vulnerabilities before real attackers do.
- Defensive security involves protecting systems through monitoring, detection, and response (SOC, blue teaming, firewalls, SIEM) to prevent and react to attacks.
- Both work together in a 'Red Team vs Blue Team' model, and 'Purple Teaming' combines both for continuous security improvement.

```
[Red Team - Offensive]  <---attack simulation--->  [Blue Team - Defensive]
  Pentesting, Exploits                              Monitoring, SOC, Firewalls
             \                                          /
              \---------  Purple Team (collab)---------/
],
```

Diagram: Red team (offense) vs blue team (defense), collaborating as purple team.

Real-World Example: Major banks like JPMorgan Chase run continuous internal red team vs blue team exercises to stress-test their defenses against realistic attack scenarios.

Q6. What is Ethical hacking? Explain domains in ethical hacking.

- Ethical hacking is the authorized practice of probing systems/networks for vulnerabilities, using the same techniques as malicious hackers but with legal permission to improve security.
- Key domains: Network penetration testing, Web application testing, Wireless security testing, Social engineering testing, and Mobile application security testing.
- Ethical hackers follow a structured methodology: reconnaissance, scanning, gaining access, maintaining access, and reporting/covering tracks (for testing purposes only).

```
Ethical Hacking Domains:
 Network Pentest | Web App Testing | Wireless Testing
 Social Engineering | Mobile App Testing | Cloud Security Testing
```

Diagram: Major domains/specializations within ethical hacking.

Real-World Example: Apple's official Security Bounty program pays ethical hackers up to $2 million for finding critical vulnerabilities in iOS, incentivizing responsible, authorized hacking.

Q7. Explain about Bug bounty hunter, VAPT, SOC.

- Bug Bounty Hunter: an independent ethical hacker who finds and reports vulnerabilities to organizations through bug bounty programs in exchange for monetary rewards.
- VAPT (Vulnerability Assessment and Penetration Testing): a combined process of scanning systems for known vulnerabilities (assessment) and actively exploiting them (penetration testing) to gauge real-world risk.
- SOC (Security Operations Center): a centralized team that continuously monitors, detects, analyzes, and responds to cyber security incidents across an organization.

```
[Bug Bounty Hunter] --reports vuln--> [Company Program (HackerOne/Bugcrowd)]
[VAPT Team] --Scan(VA) + Exploit(PT)--> [Risk Report]
[SOC Team] --24x7 Monitor--> [SIEM Dashboard] --Alert--> [Incident Response]
```

Diagram: Three key cyber security roles/functions: bug bounty, VAPT, and SOC monitoring.

Real-World Example: In 2021, a bug bounty hunter discovered a critical flaw in Western Union's system, while companies like TCS and Wipro run large SOC teams providing 24/7 monitoring services for global clients.

Q8. What is attack? Explain different types of attacks.

- A cyber attack is a deliberate attempt by an individual or group to exploit vulnerabilities in a system, network, or application to cause harm, steal data, or disrupt operations.
- Attacks are broadly classified into Passive attacks (monitoring/eavesdropping without altering data) and Active attacks (altering, disrupting, or damaging data/systems).
- Common attack types include malware, phishing, DoS/DDoS, man-in-the-middle, SQL injection, and social engineering.

```
Attack Types
  |
  +-- Passive (Eavesdropping, Traffic Analysis) - no data altered
  +-- Active  (Modification, DoS, Spoofing)      - data/system altered
```

Diagram: Top-level classification of cyber attacks: passive vs active.

Real-World Example: The 2017 Equifax data breach was an active attack that exploited an unpatched web application vulnerability, exposing personal data of 147 million people.

Q9. Explain about passive attacks and active attacks.

- Passive attacks involve monitoring or intercepting data/communications WITHOUT altering it - the goal is gathering information secretly (e.g., eavesdropping, traffic analysis).
- Active attacks involve actively modifying, disrupting, or damaging data/systems (e.g., DoS attacks, data modification, masquerading).
- Passive attacks are harder to detect since no data is changed; active attacks are easier to detect but cause direct, visible damage.

```
PASSIVE: Attacker --silently observes/copies--> Data flow (unchanged, hard to detect)
ACTIVE:  Attacker --modifies/disrupts--> Data flow (changed, easier to detect)
```

Diagram: Passive attacks observe silently; active attacks disrupt/alter directly.

Real-World Example: The NSA's mass surveillance programs revealed by Edward Snowden (2013) involved passive attacks (wiretapping/eavesdropping on global internet traffic), while the 2016 Mirai botnet DDoS attack on Dyn was a highly visible active attack.

Q10. Explain about different types of passive attacks.

- Eavesdropping (Sniffing): secretly intercepting network traffic to capture sensitive data like passwords or messages.
- Traffic Analysis: studying patterns of communication (who talks to whom, when, how much) even if the content itself is encrypted.
- Footprinting/Reconnaissance: gathering information about a target (IP ranges, employee names, technology used) before launching an attack.

```
Passive Attack Types:
 Eavesdropping/Sniffing -> capture data in transit
 Traffic Analysis       -> study communication patterns
 Reconnaissance          -> gather target information
```

Diagram: Common passive attack techniques used for silent information gathering.

Real-World Example: Attackers commonly use free/public Wi-Fi hotspots at airports and cafes to passively sniff unencrypted traffic from unsuspecting users' devices, capturing login credentials.

Q11. Explain about different types of active attacks.

- Denial of Service (DoS/DDoS): overwhelming a system with traffic/requests to make it unavailable to legitimate users.
- Masquerading/Spoofing: pretending to be another entity (IP spoofing, email spoofing) to gain unauthorized access or trust.
- Data Modification & Replay attacks: altering data in transit, or capturing and resending valid data packets to trick a system into unauthorized actions.

```
Active Attack Types:
 DoS/DDoS      -> flood system, deny service
 Spoofing      -> impersonate a trusted entity
 Modification / Replay -> alter or resend captured data
```

Diagram: Common active attack techniques that directly disrupt or manipulate systems.

Real-World Example: The October 2016 Mirai botnet DDoS attack on Dyn (a DNS provider) took down major websites like Twitter, Netflix, and Reddit for hours by flooding servers with traffic from hacked IoT devices.

Q12. Differences between passive attacks and active attacks.

- Passive attacks only observe/intercept data without changing it; active attacks modify, damage, or disrupt data/systems.
- Passive attacks are difficult to detect (no visible trace); active attacks are easier to detect due to noticeable system/data changes.
- Passive attacks focus on data confidentiality breach (spying); active attacks target integrity and availability (damage/disruption).

```
PASSIVE: Confidentiality risk | Hard to detect | e.g. Eavesdropping
ACTIVE:  Integrity/Availability risk | Easier to detect | e.g. DoS, Spoofing
```

Diagram: Key differences in detectability and impact: passive vs active attacks.

Real-World Example: Chinese state-sponsored group APT10's 'Cloud Hopper' campaign (revealed 2017) used long-term passive espionage (data theft) across managed service providers, contrasted with the loud, active 2017 NotPetya attack that destroyed data across companies like Maersk.

Q13. What is cyberattack? Explain about malware.

- A cyberattack is any malicious, deliberate attempt to exploit weaknesses in computer systems, networks, or software to steal, damage, or disrupt data/operations.
- Malware (Malicious Software) is a broad category of software specifically designed to damage, disrupt, or gain unauthorized access to a system.
- Malware is one of the most common tools used to carry out cyberattacks, spreading via infected email attachments, malicious downloads, or compromised websites.

```
[Attacker] --creates--> [Malware] --delivered via Email/Download/USB--> [Victim System: infected]
```

Diagram: Malware as a tool used to carry out a broader cyberattack.

Real-World Example: The 2017 NotPetya malware attack, initially disguised as ransomware, caused over $10 billion in global damages, severely crippling companies like Maersk and Merck.

Q14. What is malware? Explain about different types of malware.

- Malware is any software intentionally designed to cause damage, steal data, or gain unauthorized access to a computer system.
- Main types: Virus (attaches to files, needs host to spread), Worm (self-replicates independently), Trojan Horse (disguised as legitimate software), Ransomware (encrypts data for ransom), Spyware (secretly monitors activity).
- Malware can be delivered via phishing emails, malicious downloads, infected USB drives, or exploiting unpatched software vulnerabilities.

```
Malware
  |
  +-- Virus         (needs host file)
  +-- Worm          (self-replicating)
  +-- Trojan Horse   (disguised as legit software)
  +-- Ransomware     (encrypts & demands payment)
  +-- Spyware        (secretly monitors)
```

Diagram: Major categories of malware and how they behave.

Real-World Example: The 2021 Kaseya ransomware attack (REvil group) affected up to 1,500 businesses globally by exploiting a software supply-chain vulnerability to deploy ransomware.

Q15. Explain about spyware.

- Spyware is malicious software that secretly monitors and collects a user's activity (browsing habits, keystrokes, login credentials) without their knowledge or consent.
- It often runs silently in the background, sending collected data to a remote attacker, and can include keyloggers, tracking cookies, or system monitors.
- Spyware is often bundled with free software downloads, malicious ads (malvertising), or phishing links.

```
[User Activity: keystrokes, browsing] --Secretly Captured by Spyware--> [Sent to Attacker's Server]
```

Diagram: Spyware silently captures user activity and exfiltrates it to an attacker.

Real-World Example: The 2021 Pegasus spyware scandal (NSO Group) revealed that sophisticated spyware was used to secretly monitor journalists, activists, and politicians' smartphones worldwide via zero-click exploits.

Q16. Explain about Virus.

- A computer virus is a malicious program that attaches itself to a legitimate file/program and spreads when that infected file is executed or shared.
- It requires human action (opening an infected file/attachment) to activate and spread - it cannot replicate on its own like a worm.
- Viruses can corrupt files, steal data, slow down systems, or provide backdoor access, and are often spread via infected email attachments or downloads.

```
[Clean File] --Virus attaches--> [Infected File] --User Opens It--> [Virus Activates & Spreads]
```

Diagram: A virus attaches to a host file and activates when the user opens it.

Real-World Example: The 'ILOVEYOU' virus (2000) spread via email attachments disguised as a love letter, infecting over 45 million Windows computers worldwide and causing billions in damages.

Q17. Explain about Worm.

- A computer worm is a self-replicating malware that spreads automatically across networks WITHOUT needing to attach to a host file or require human action.
- It exploits vulnerabilities in operating systems/network protocols to move from one system to another, often consuming bandwidth and system resources rapidly.
- Worms can carry additional payloads (like ransomware or backdoors), making them highly destructive at scale.

```
[Infected System] --exploits network vulnerability--> [System 2] --auto-spreads--> [System 3] --> ...
            (No human action needed, spreads automatically)
```

Diagram: A worm self-propagates across a network without needing a host file or user action.

Real-World Example: The WannaCry worm (2017) exploited the EternalBlue SMB vulnerability to self-propagate across networks, infecting over 200,000 computers in 150 countries within days, including UK's NHS.

Q18. Explain about trojan horse.

- A Trojan Horse is malware disguised as legitimate, harmless software to trick users into voluntarily installing it.
- Unlike viruses/worms, Trojans do NOT self-replicate - they rely entirely on social engineering/deception to get executed by the victim.
- Once activated, Trojans can create backdoors, steal data, install additional malware, or give attackers remote control of the system.

```
[Attacker] --disguises malware as "free_software.exe"--> [User downloads & runs it]
                  --> [Trojan opens backdoor for attacker]
```

Diagram: A Trojan disguises itself as legitimate software to trick users into installing it.

Real-World Example: The Emotet Trojan, first seen as a banking Trojan in 2014, evolved into one of the world's most dangerous malware delivery platforms, distributing ransomware to organizations globally until it was disrupted by a global law enforcement operation in 2021.

Q19. Explain about ransomware.

- Ransomware is malware that encrypts a victim's files or locks their system, demanding a ransom payment (often in cryptocurrency) for the decryption key.
- It typically spreads via phishing emails, malicious attachments, or exploiting unpatched vulnerabilities, and can rapidly spread across an entire network.
- Modern ransomware often uses 'double extortion' - stealing data before encrypting it, and threatening to leak it publicly if the ransom isn't paid.

```
[Victim Files] --Ransomware Encrypts--> [Locked Files: .encrypted]
     Screen: "Pay $X in Bitcoin to receive decryption key"
```

Diagram: Ransomware encrypts victim data and demands payment for the decryption key.

Real-World Example: The May 2021 Colonial Pipeline ransomware attack (DarkSide group) forced the shutdown of a major US fuel pipeline, causing fuel shortages across the East Coast, with the company paying a $4.4 million ransom.

Q20. Differences between virus and worm.

- A virus needs to attach itself to a host file and requires human action (opening the file) to spread; a worm is standalone and self-replicates automatically across networks without human action.
- Viruses typically spread slower (dependent on file sharing/execution); worms spread much faster since they exploit network vulnerabilities directly.
- Viruses mainly corrupt/damage files on the infected system; worms often consume network bandwidth and resources while spreading, potentially carrying additional payloads.

```
VIRUS: needs host file + human action  -> spreads slower (email attachments)
WORM:  standalone, self-replicating    -> spreads faster (network exploit, no action needed)
```

Diagram: Key contrast: virus requires a host and user action; worm spreads independently.

Real-World Example: ILOVEYOU (2000) was a virus needing users to open an email attachment, while WannaCry (2017) was a worm that spread automatically across networks without any user interaction.

Q21. What is pretending? Explain various types of attacks under pretending.

- 'Pretending' (impersonation-based attacks) refers to attackers disguising themselves as a trusted person, entity, or system to deceive victims into revealing information or granting access.
- Common types under this category: Phishing (fake emails/messages pretending to be legitimate), Spoofing (faking IP/email/website identity), and Social Engineering (psychologically manipulating people).
- Pharming is a related technique that redirects users to fake websites even when they type the correct URL, by tampering with DNS.

```
Pretending / Impersonation Attacks
  |
  +-- Phishing        (fake emails/messages)
  +-- Spoofing        (fake IP/email/website identity)
  +-- Social Engineering (psychological manipulation)
  +-- Pharming        (DNS-based redirection to fake sites)
```

Diagram: Impersonation-based attack types grouped under 'pretending'.

Real-World Example: The 2016 Democratic National Committee (DNC) email hack began with a phishing email pretending to be a Google security alert, tricking a campaign chairman into revealing his password.

Q22. What is phishing attack? Explain with a real time example.

- Phishing is a social engineering attack where attackers send fraudulent messages (usually emails) that appear to come from a trusted source, tricking victims into revealing sensitive information or clicking malicious links.
- It often creates urgency or fear (e.g., 'Your account will be suspended') to pressure victims into acting quickly without verifying authenticity.
- Variants include spear phishing (targeted at a specific individual), whaling (targeting executives), and smishing/vishing (via SMS/voice calls).

```
[Attacker] --sends fake "bank" email--> [Victim] --clicks link--> [Fake Login Page]
     --enters credentials--> [Attacker steals login info]
```

Diagram: Typical phishing attack flow: fake message leads to credential theft.

Real-World Example: In 2016, a spear-phishing email impersonating Google alerted John Podesta (Hillary Clinton's campaign chairman) to 'change his password' via a fake link, leading to the massive DNC email leak that impacted the US presidential election.

Q23. Explain about different types of phishing attacks.

- Spear Phishing: a highly targeted phishing attack aimed at a specific individual or organization, using personalized information to appear more convincing.
- Whaling: phishing targeted specifically at senior executives (CEOs, CFOs) to authorize fraudulent wire transfers or reveal sensitive company data.
- Smishing (SMS phishing) and Vishing (Voice phishing): phishing conducted via text messages or phone calls instead of email.

```
Phishing Types:
 Spear Phishing -> targeted individual
 Whaling        -> targeted executives
 Smishing       -> via SMS
 Vishing        -> via voice call
```

Diagram: Variants of phishing categorized by target and delivery channel.

Real-World Example: In 2019, a Toyota subsidiary lost $37 million to a Business Email Compromise (whaling-style) attack where fraudsters impersonated a business partner requesting a wire transfer change.

Q24. Explain about spoofing.

- Spoofing is a technique where an attacker disguises their identity (IP address, email address, website, or caller ID) to appear as a trusted source.
- Common types: IP spoofing (faking source IP in packets), Email spoofing (faking sender address), DNS spoofing (redirecting domain lookups), and Caller ID spoofing.
- Spoofing is often used to bypass security controls, launch further attacks (like DDoS), or trick victims into trusting malicious communication.

```
[Attacker: real IP=X] --sends packet with fake Src IP=Y--> [Victim believes it's from trusted source Y]
```

Diagram: IP spoofing: attacker disguises the source of network traffic.

Real-World Example: GPS spoofing incidents near the Black Sea and other conflict zones (reported by aviation/maritime authorities in the 2020s) have caused ships and aircraft navigation systems to show false locations.

Q25. Explain about social engineering.

- Social engineering is the psychological manipulation of people into performing actions or divulging confidential information, exploiting human trust rather than technical vulnerabilities.
- Common techniques: pretexting (creating a fake scenario), baiting (offering something enticing like a free USB drive), tailgating (physically following someone into a secure area), and phishing.
- It is often considered the weakest link in security because even the strongest technical defenses can be bypassed by tricking a human user.

```
[Attacker] --builds trust/urgency/fear--> [Human Target] --reveals info / grants access--> [Attacker succeeds]
    (Exploits psychology, not technology)
```

Diagram: Social engineering exploits human psychology rather than technical flaws.

Real-World Example: The 2020 Twitter Bitcoin scam hack was executed via social engineering - attackers phone-tricked Twitter employees into giving up internal admin tool access, allowing them to hijack accounts of Obama, Musk, and Biden to post a Bitcoin scam.

Q26. Explain about pharming.

- Pharming is a cyberattack that redirects users from a legitimate website to a fraudulent one, even when they type the correct URL, without needing them to click a malicious link.
- It works by corrupting DNS resolution (DNS cache poisoning) or modifying the victim's local host file, so the domain name resolves to the attacker's fake IP address.
- Because the URL bar can look correct, pharming is more dangerous and harder to detect than typical phishing, often used to steal banking credentials.

```
User types: www.mybank.com
  Normal:  DNS --> Real Bank IP --> Real Website
  Pharming: DNS (poisoned) --> Fake IP --> Fake Website (looks identical, steals login)
```

Diagram: Pharming redirects users to a fake site via DNS manipulation, even with a correct URL.

Real-World Example: In 2007, a large-scale pharming attack targeted over 50 financial institutions worldwide by exploiting a DNS server vulnerability, redirecting customers to fake banking sites to harvest credentials.